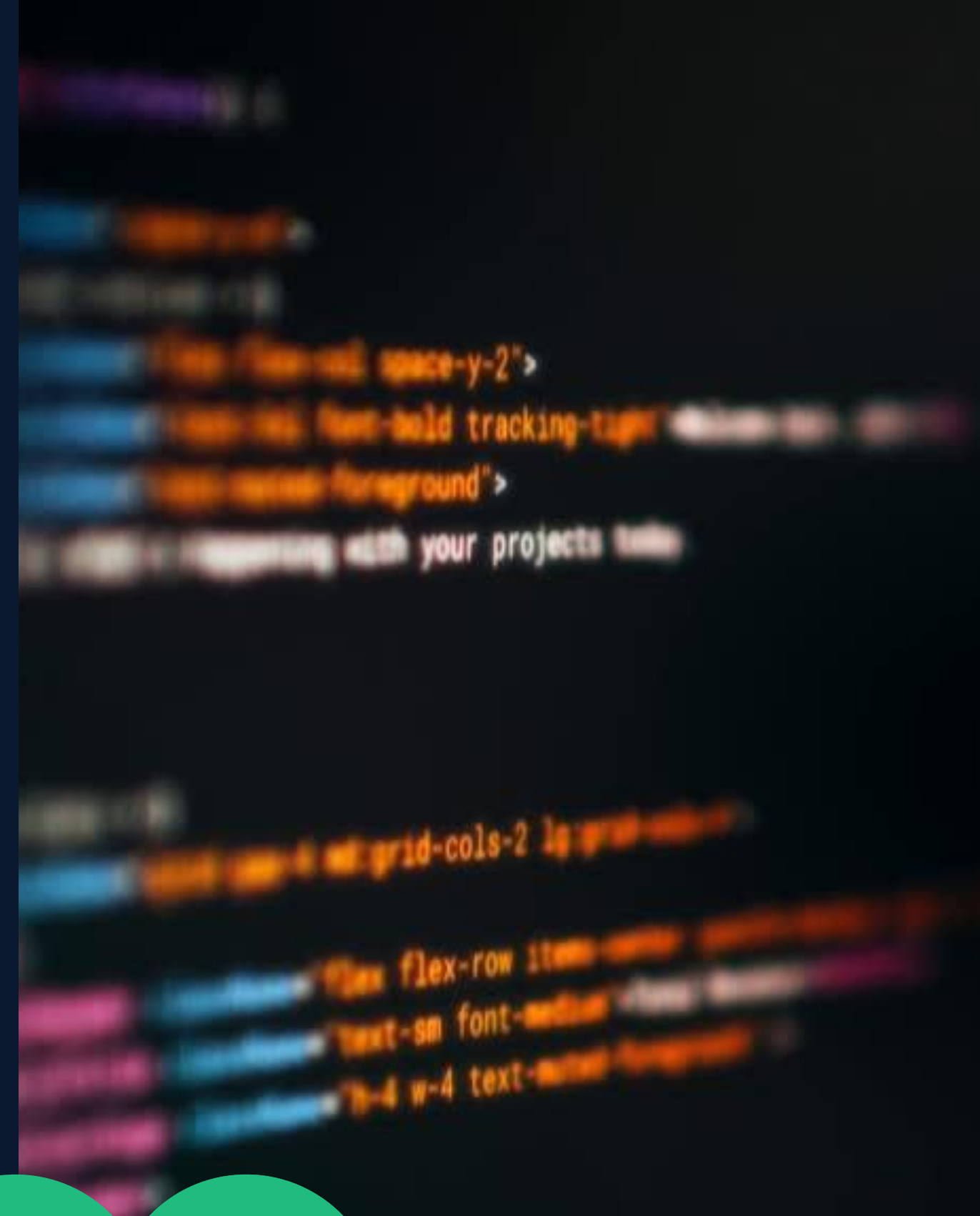
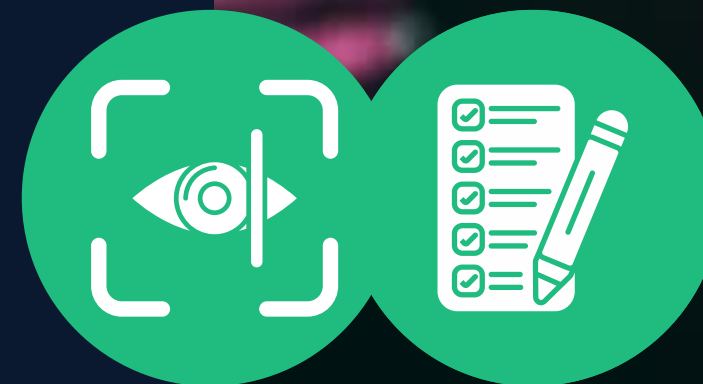


MULTIMEDIA UNIVERSITY, MALAYSIA

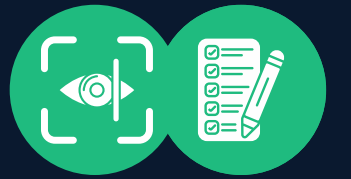
Enumeration

ETHICAL HACKING AND PENETRATION TESTING
CCS6324 - 2530

Dr. Hafiz Adnan Hussain

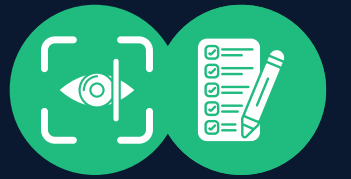


DISCLAIMER



- This course is designed to educate students on ethical hacking principles. The knowledge and techniques acquired must be used responsibly and not for any illegal or unauthorized activities.
- Each student is solely responsible for their actions.
- Do not investigate individuals, websites, servers or conduct any illegal activities on any system you do not have permission to analyze.
- The course content has been developed in good faith, drawing from the author's experience and reputable sources. While every effort has been made to ensure accuracy, the author does not guarantee absolute correctness. Students are encouraged to exercise discretion and actively engage in discussions by raising any questions or concerns during the course.

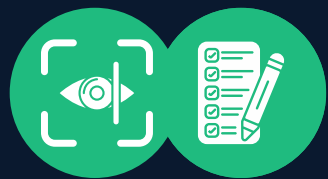
Learning Objectives



What You Will Learn?

- Understand enumeration as an active information-gathering phase
- Extract detailed information from target systems using various enumeration techniques
- Distinguish between scanning and enumeration techniques
- Enumerate different operating systems (Windows, Linux, NetWare) and identify their network services
- Exploit NULL sessions and NetBIOS vulnerabilities
- Identify security misconfigurations that could lead to unauthorized access
- Apply enumeration tools effectively in authorized penetration testing scenarios

INTRODUCTION TO ENUMERATION



What is Enumeration?

Enumeration is the process of extracting detailed information from target systems on a network.

Key Characteristics:

- Active probing - sends traffic to targets and receives responses
- Targeted information gathering - focuses on specific services and accounts
- Can be detected by security monitoring systems
- More intrusive than reconnaissance but less obvious than vulnerability scanning

The Reconnaissance Process

Port scanning is **Step 4** in the hacking process:

Step 1: Footprinting → "Who is the target?"

Step 2: Reconnaissance → "What domains do they own?"

Step 3: Port Scanning → "What services are running?"

Step 4: Enumeration → "What versions? What users?" ← WE ARE HERE

Step 5: Exploitation → "Attack the vulnerable service"

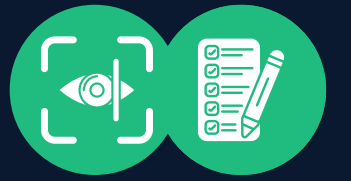
Information extracted through enumeration includes:

- System and OS info (names, versions, patch level, drivers, NetBIOS)
- User accounts and group memberships
- Shared resources (folders, printers, files) and their permissions
- Running services and processes
- Network configuration (routes, DNS, gateways)
- Security controls (firewall rules, antivirus)
- NULL session vulnerabilities (if present)

Scanning vs Enumeration:

Aspect	Scanning	Enumeration
Goal	Find open ports	Extract service details
Scope	Network-wide	Service-specific

Enumeration of Different Operating Systems (OS)



Windows OS Enumeration

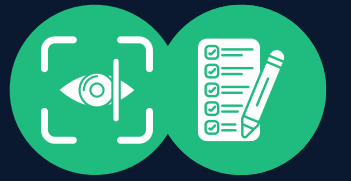
Common Windows Services and Protocols:

- **NetBIOS (Port 139):** Legacy name resolution service. Allows discovery of Windows computers on the local network.
- **SMB/CIFS (Port 445):** File sharing and printer sharing protocol. Contains valuable information about shares and users.
- **RPC (Port 135): Remote Procedure Call.** Used for remote management and service queries.
- **LDAP (Port 389): Lightweight Directory Access Protocol.** Queries Active Directory for users and groups.

Why Command-Line Tools?

- Faster than GUI navigation in penetration testing scenarios
- Can be automated and scripted
- Often available even on restricted systems
- Can be executed remotely
- Output can be piped and filtered for specific information

Enumeration of Different Operating Systems (Cont'd)



Windows Version and Patch Information

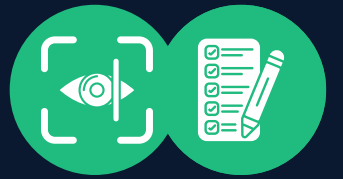
Why Version History Matters: Each Windows version introduced new security features:

- **Windows 95/98/ME:** No native security, DOS-based, no real user separation
- **Windows NT:** Introduced NTFS (New Technology File System) permissions, domains, and basic user authentication
- **Windows 2000:** Added Active Directory, Kerberos authentication, and Group Policies
- **Windows XP SP2+:** Built-in Firewall enabled by default, DEP (Data Execution Prevention), early UAC (User Access Control) concepts, Security Center
- **Windows Vista/7+:** UAC fully implemented, ASLR (Address Space Layout Randomization), BitLocker full-disk encryption, Secure Boot groundwork
- **Windows 10:** Device Guard, Credential Guard, Windows Hello biometric login, improved Defender ATP (Advanced Threat Protection), sandboxing improvements
- **Windows 11 (Modern Security):** Trusted Platform Module (TPM) 2.0 requirement, Secure Boot enforcement, VBS/HVCI default-on, Smart App Control, Pluton chip support, enhanced Windows Hello, improved ransomware protection

Knowing the version helps identify:

- Available exploits and known vulnerabilities
- Security mechanisms likely to be present
- Legacy protocols that might be enabled

Enumeration of Different Operating Systems (Cont'd)



Windows 11: Modern Security, Zero-Trust, and Hardware Enforcement

Here are the key security innovations in **Windows 11**:

1. Mandatory Hardware-Based Security (TPM 2.0 & Secure Boot)

- Requires TPM 2.0 for all devices
- Enforces UEFI Secure Boot
- Ensures cryptographic root-of-trust
- Protects against boot-level malware and firmware attacks

2. Virtualization-Based Security (VBS) On by Default

- Memory integrity (HVCI)
- Enforces Hyper-V isolation
- Prevents kernel-level exploits, driver attacks, and credential theft

3. Enhanced Windows Hello & Passwordless Security

- Facial recognition, fingerprint, PIN stored in TPM
- Push for passwordless Microsoft accounts
- Phishing-resistant authentication

4. Pluton Security Processor Support

- Integration with CPU (AMD/Intel/Qualcomm, depending on model)
- Protects encryption keys against physical attacks
- Designed for Zero-Trust endpoint security

5. Improved Smart App Control

- Uses AI + code integrity policies
- Blocks untrusted or unsigned apps
- Helps prevent ransomware execution

6. Better Secure Kernel & Memory Protections

- Hardware-enforced stack protection
- Improved ASLR
- Control-flow integrity (CFI)
- Kernel-mode driver signing policies are stricter than Windows 10

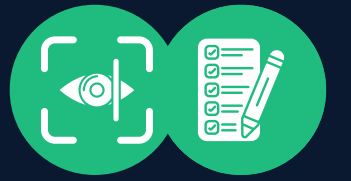
7. Built-in Ransomware Protection

- Controlled Folder Access
- Cloud-based ML detection
- OneDrive recovery integration

8. Enhanced Microsoft Defender

- Defender SmartScreen anti-phishing
- Defender for Endpoint onboarding
- Automatic isolation of suspicious processes
- Firmware-level scanning

Enumeration of Different Operating Systems (Cont'd)



Windows OS Enumeration

Commands to Enumerate Windows Version

Method 1: systeminfo

```
C:\> systeminfo
```

Shows: OS Name, OS Version, System Boot Time, Processor(s), Hotfix(s), KB numbers

Method 2: Using WMI (Windows Management Instrumentation) - Deprecated

```
C:\> wmic qfe list
```

Shows: Installed patches/hotfixes in a detailed table

```
C:\> wmic os get version
```

Shows: OS version number

Method 3: PowerShell (Modern Windows)

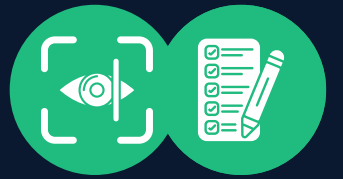
```
PS C:\> Get-Hotfix | Select-Object HotFixID, InstalledOn
```

Shows: Patches with installation dates

```
PS C:\> [System.Environment]::OSVersion.Version
```

Shows: Full OS version information

Enumeration of Different Operating Systems (Cont'd)



Windows Services Enumeration

Services run with SYSTEM or high privileges. Misconfigured services are common privilege escalation vectors.

Commands to Enumerate Services

Method 1: SC command (Service Control)

```
C:\> sc query
```

Lists all services and their states (RUNNING, STOPPED, etc.)

Method 2: Net command

```
C:\> net start
```

Shows: Running services only

Method 3: WMI

```
C:\> wmic service list brief
```

Shows: Service name, display name, state

```
C:\> wmic service get name,state,pathname
```

Shows: Service executable path (critical for privilege escalation)

Method 4: PowerShell

```
PS C:\> Get-Service
```

Shows: Service status in table format

Service Privilege Escalation Vectors

Unquoted Service Paths

If the service path is not quoted and contains spaces, Windows will try to execute intermediate paths.

Example: C:\Program Files\My Service\service.exe

Windows tries: C:\Program.exe, C:\Program Files\My.exe, then correct path

Find unquoted paths:

```
C:\> wmic service get name,pathname | findstr /i /v "C:\Windows\\" |  
findstr /i /v "\"
```

Insecure Service Permissions

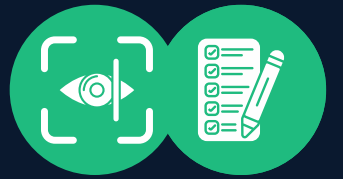
Services with weak permissions can have their executable or configuration modified by non-admin users.

Check with Sysinternals accesschk:

```
C:\> accesschk -ucqw *
```

Shows: Services with weak permissions (look for WRITE access)

Enumeration of Different Operating Systems (Cont'd)



Windows Accounts and Groups

Enumerate current user:

```
C:\> whoami
```

```
C:\> whoami /all
```

Shows: Current user and group membership with SIDs

Enumerate local users and groups:

```
C:\> net user
```

Lists all local user accounts

```
C:\> net user username
```

Shows: Account details (last login, password requirements, groups)

```
C:\> net localgroup
```

Lists all local groups

```
C:\> net localgroup Administrators
```

Shows members of the Administrators group (high-value targets)

Enumerate Active Directory (domain environments):

```
C:\> net group "Domain Admins" /domain
```

Shows: All domain admin accounts

```
C:\> net user /domain
```

Shows: Domain users (if not restricted)

Network Configuration

```
C:\> ipconfig /all (Shows: All network adapters, DHCP, DNS servers, IP configuration)
```

```
C:\> route print (Shows: Routing table, available networks, and gateways)
```

```
C:\> arp -a (Shows: ARP cache, recently accessed IP addresses, and MAC addresses)
```

```
C:\> netstat -ano (Shows: Active connections, listening ports, Process IDs)
```

```
C:\> net share (Shows: Shared folders and printers)
```

Security Software Detection

Antivirus Detection

```
C:\> sc query windefend
```

Checks Windows Defender status

```
C:\> wmic /namespace:\\root\SecurityCenter2 path AntivirusProduct
```

Lists all antivirus products on the system

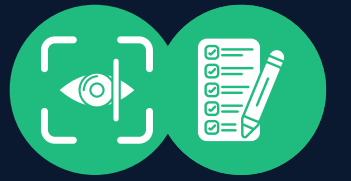
```
PS C:\> Get-MpComputerStatus (PowerShell: Detailed Windows Defender status)
```

Firewall Detection

```
C:\> netsh advfirewall firewall show rule name=all (Shows: All firewall rules in detail)
```

```
C:\> netsh advfirewall show currentprofile (Shows: Current firewall profile (Domain, Private, Public))
```

Enumeration of Different Operating Systems (Cont'd)



NetBIOS Enumeration

NetBIOS Basics: NetBIOS (Network Basic Input/Output System) is a legacy Windows naming and communication protocol.

Used for: File and printer sharing, network browsing, and name resolution. **Ports:** **137** (UDP name service), 138 (UDP datagram), 139 (TCP session)

NetBIOS Name Format

Limit: 15 characters + 1 service identifier = 16 characters total

Example: MYCOMPUTER__<20> where <20> indicates FILE SERVER service

Why This Matters:

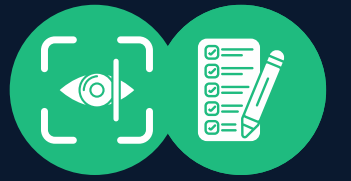
- Finding <20> indicates a system with file sharing enabled
- Multiple <1C> entries indicate multiple domain controllers
- Presence of RAS (<06>) shows remote access configured

NetBIOS Service Suffixes

The last character of a NetBIOS name indicates what service is running:

- <00> = Workstation service (general computer)
- <01> = Master browser (network discovery)
- <03> = Messenger service (network messages)
- <06> = RAS server (remote access)
- <1F> = NetDDE (Network Dynamic Data Exchange)
- <20> = Server service (file/print sharing)
- <21> = RAS client
- <22> = Exchange Interchange
- <23> = Exchange Store
- <1B> = Domain Master Browser
- <1C> = Domain Controllers
- <1D> = Master Browser
- <1E> = Browser Election

Enumeration of Different Operating Systems (Cont'd)



Linux/Unix OS Enumeration

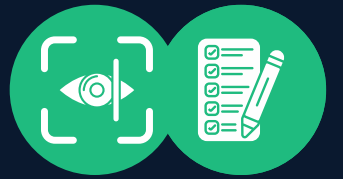
Common Linux Services and Protocols:

- **NFS (Port 2049):** Network File System. Shares files across the network. Often misconfigured.
- **SNMP (Port 161):** Simple Network Management Protocol. Reveals system information, users, running processes.
- **SMTP (Port 25):** Simple Mail Transfer Protocol. Can enumerate valid user accounts through mail server.
- **SSH (Port 22):** Secure Shell. Version enumeration reveals OS and SSH version.

What Linux Enumeration Reveals:

- System uptime and load averages
- System users and groups
- Running processes and services
- Available NFS shares
- System hardware and network configuration

Enumeration of Different Operating Systems (Cont'd)



Linux/Unix OS Enumeration (Cont'd)

Why Knowing the Distribution Matters

- Different distributions have different default packages and configurations
- Various *NIX flavors: Solaris, HP-UX, AIX, FreeBSD, OpenBSD, NetBSD, Darwin/macOS
- Each has unique enumeration approaches and vulnerable services

Check Linux distribution:

```
$ cat /etc/lsb-release
```

```
$ lsb_release -a
```

Check kernel version:

```
$ uname -a
```

Shows: Kernel version (critical for kernel exploits)

Linux Services and Processes

If systemd is used (modern Linux):

```
$ systemctl --type=service (Lists all services)
```

```
$ systemctl --type=service --all (Lists all services, including disabled ones)
```

View running processes:

```
$ ps aux (Shows: All running processes with full details)
```

```
$ ps aux --forest (Shows: Process tree with parent/child relationships)
```

Linux User and Group Enumeration

```
$ cat /etc/passwd (Shows: All user accounts (format: username:password:UID:GID:comment:home:shell))
```

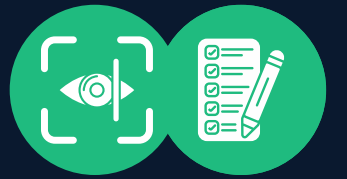
```
$ cat /etc/group
```

Shows: All groups and their members

```
$ cat /etc/shadow
```

Shows: Password hashes (requires root access)

Enumeration of Different Operating Systems (Cont'd)



Linux/Unix OS Enumeration (Cont'd)

SUID/SGID Binaries (Privilege Escalation)

SUID binaries run with the owner's privileges, often with escalation vectors

\$ find / -perm -u=s -type f (Finds all SUID binaries on system)

\$ find / -perm -4000 (Alternative: finds SUID files (octal 4000))

\$ find / -perm -2000 (Finds SGID files (octal 2000))

Linux Network Enumeration

\$ ip addr (Shows: All network interfaces and IP addresses (modern))

\$ ip route (Shows: Routing table and available networks)

\$ ip link (Shows: Network interfaces and status)

\$ ss -ltpn (Shows: Listening ports with associated programs (modern netstat))

\$ netstat -tulpn (Shows: Listening ports (older Linux systems))

Linux Firewall Enumeration

If using iptables:

\$ iptables -L -n

Shows: Current firewall rules

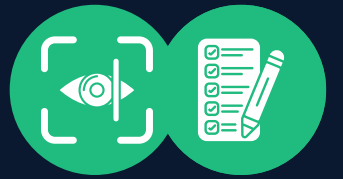
If using nftables (newer):

\$ nft list ruleset

If using firewalld:

\$ firewall-cmd --list-all

Remote Enumeration Tools



SNMP (Simple Network Management Protocol)

Port: 161 (UDP)

Purpose: Remote monitoring and management of network devices

Reveals: System info, running processes, installed software, network config

Default community strings: "public" (read), "private" (write)

\$ snmpwalk -c public -v 1 TARGET_IP (Walks the entire SNMP tree with "public" community string)

Finger Service

Port: 79 (TCP)

Purpose: Display information about system users

Shows: Logged-in users, login times, idle time

\$ finger @TARGET_IP (Gets info about all logged-in users)

\$ finger username@TARGET_IP (Gets specific user information)

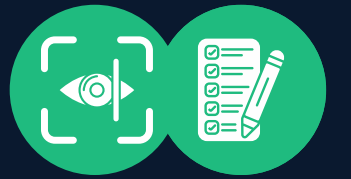
Nessus / OpenVAS

Comprehensive vulnerability assessment tools

Combines enumeration with vulnerability scanning

Provides detailed reports on systems found

Banner Grabbing Techniques



Banner grabbing is extracting version information from services. Services often display information about themselves when you connect to them.

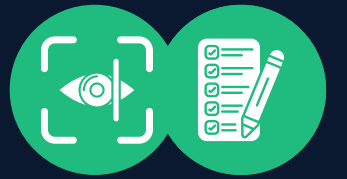
Why Banner Grabbing is Important:

- Identifies specific service versions
- Reveals known vulnerabilities
- Helps in attack planning
- Can be done passively or actively

Common Banner Grabbing Methods:

- 1. Telnet Connection:** `telnet target_ip port` - connects and captures banner
- 2. Netcat:** `nc target_ip port` - lightweight banner grabbing
- 3. Nmap Scripts:** `nmap -sV target_ip` - service version detection
- 4. Curl/Wget:** Web server banner grabbing

NULL Session Attacks - A Critical Windows Vulnerability



A NULL session is an unauthenticated connection to a Windows system that can be used to extract information without providing credentials (by using empty username and password).

Why NULL Sessions Are Dangerous:

- No authentication is required, so it can reveal information (system policies and configurations) for further attacks to enumerate user and group accounts (with details, disabled, password policies, Security Identifiers), shared resources, access rights, and network structure
- Older Windows OS (before Windows Server 2003, e.g., NT, 2000, XP (before SP2 in some cases)) are vulnerable

Exploiting NULL Sessions:

Step 1: Create NULL Session

C:\> net use \\TARGET_IP\IPC\$ "" /u:"" (It creates an unauthenticated connection to IPC\$ share (Inter-Process Communication))

Step 2: Enumerate Resources

C:\> net view \\TARGET_IP

After establishing a NULL session, this now works (without it, it would fail)

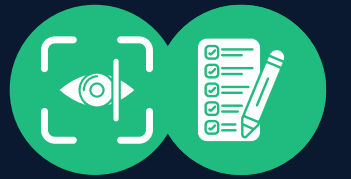
Step 3: Get User Information

C:\> RID enum 4 TARGET_IP

Enumerates all users and their RIDs (Relative IDs)

Modern tool in Kali: enum4linux automatically attempts NULL sessions

Security Implications & Defense



Why Enumeration Matters:

- Information disclosure - reveals system details that aid attackers
- Privilege escalation planning - helps identify targets for escalation
- Lateral movement - shows available shares and systems to target
- Credential harvesting - identifies valid user accounts to attack

Defense Against Enumeration

Windows:

- Disable NetBIOS on systems that don't require it
- Restrict NULL session connections via registry
- Remove default shares (C\$, IPC\$, ADMIN\$)
- Configure firewalls to block unnecessary ports 137-139 and 445
- Implement strong SNMP community strings
- Disable unnecessary services (NFS, SMTP, SNMP if not needed)
- Monitor enumeration attempts in security logs

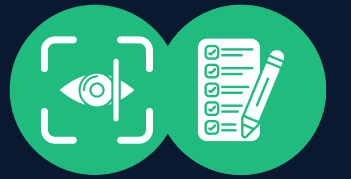
Linux/UNIX:

- Disable or restrict SNMP (or use SNMPv3 with authentication)
- Disable Finger service (port 79)
- Configure the host firewall to block unnecessary ports
- Limit file permissions on sensitive files (/etc/passwd, /etc/shadow)
- Disable SUID on unnecessary binaries

General:

- Monitor and log enumeration attempts (port scanning, service probing)
- Implement network segmentation
- Use IDS/IPS to detect suspicious scanning behavior
- Keep systems patched and updated

Key Concepts Summary



Remember these key points:

- Enumeration is an active probing that can be detected
- Command-line tools are faster and more efficient than GUI tools
- Different OS require different tools: Windows (NBTscan, SMB), Linux (SNMP, NFS)
- Information extracted through enumeration directly enables further attacks
- NULL sessions are unauthenticated access to Windows systems - a critical vulnerability
- Proper enumeration requires authorization and documentation

Thank You

ANY QUESTIONS?

